INFORME TÉCNICO

Análisis y mejora de seguridad de una aplicación Android

Proyecto: GPSMapApp

Estudiantes: Matias Mundaca, Sebastian Pereira y Cristian Pereira

Asignatura: Programación Android

Docente: Oscar Monardez

Institución: IP Ovalle Santo Tomás

Fecha: 30/10/2026

1. Introducción

Este informe documenta la revisión de seguridad de GPSMapApp, una aplicación Android desarrollada en Java. La aplicación muestra Google Maps y la ubicación actual, permite añadir marcadores, obtener direcciones mediante geocodificación inversa y capturar fotografías. También incorpora registro e inicio de sesión con SQLite.

La revisión del código fuente confirma controles de consultas parametrizadas, derivación de contraseñas con PBKDF2 y salt, control local de intentos de inicio de sesión, sesión mínima en preferencias privadas, desactivación de backups y configuración para impedir tráfico HTTP en claro. Se identifican además tareas pendientes, especialmente la revocación de una clave Maps que apareció en un artefacto histórico y la ejecución de pruebas sobre el APK actualizado.

2. Objetivos

- Identificar riesgos relevantes en autenticación, almacenamiento, comunicaciones, configuración y permisos.
- Describir controles presentes en el código y sus limitaciones.
- Definir pruebas reproducibles y un plan de mejora continua.

3. Descripción y alcance

Proyecto: GPSMapApp, paquete com.example.semana9. Tecnologías observadas: Java, Android SDK (compileSdk 37, minSdk 30), Google Maps SDK, Fused Location Provider, SQLite, AndroidX y Gradle Kotlin DSL.

Componentes revisados: LoginActivity, RegisterActivity, MainActivity, DatabaseHelper, SessionManager, LoginAttemptGuard, LoginService, PrefsAttemptStore, AndroidManifest.xml, configuración Gradle y recursos XML de backup y seguridad de red.

4. Vulnerabilidades y controles

4.1 Inyección SQL

En DatabaseHelper.java, las consultas a la tabla users utilizan parámetros ? y selectionArgs; las inserciones usan ContentValues. No se observó concatenación de entradas de usuario para construir consultas. Esto mitiga la inyección SQL en la capa SQLite revisada. Se recomienda ejecutar pruebas con payloads de inyección contra el APK final y adjuntar resultados; esta revisión no ejecutó esas pruebas dinámicas.

4.2 Comunicación no segura

El proyecto utiliza Google Maps/Location y no declara un backend propio. Se agregó en esta entrega app/src/main/res/xml/network_security_config.xml con cleartextTrafficPermitted=false y anclas de confianza del sistema. AndroidManifest.xml referencia esa configuración y declara usesCleartextTraffic=false. No se configuró certificate pinning. La inclusión debe verificarse compilando y analizando el APK actualizado; el escaneo MobSF histórico no contiene esta corrección.

4.3 Exposición de datos sensibles

DatabaseHelper deriva las contraseñas con PBKDF2-HMAC-SHA256, 100.000 iteraciones, salt aleatoria de 16 bytes y salida de 256 bits. La sesión usa SharedPreferences privadas (MODE_PRIVATE), contiene user_id, username y login_at, caduca a los siete días y se limpia al cerrar sesión. Las preferencias de sesión no están cifradas; no se debe afirmar uso de EncryptedSharedPreferences o Android Keystore.

La clave de Google Maps se obtiene desde local.properties o MAPS_API_KEY y se inyecta mediante manifestPlaceholders. local.properties se excluye de Git. Sin embargo, el PDF MobSF histórico incluido originalmente en el ZIP contenía una clave literal.

Por precaución, el PDF original fue retirado del paquete y sustituido por un resumen redactado. La clave histórica debe revocarse y reemplazarse manualmente en Google Cloud, con restricciones por paquete, SHA-1 y API.

4.4 Fuerza bruta

LoginService aplica LoginAttemptGuard antes de verificar credenciales. El control cuenta intentos por nombre de usuario normalizado, permite cinco intentos y luego establece bloqueos progresivos desde 30 segundos hasta un máximo de 900 segundos. PrefsAttemptStore persiste el estado en SharedPreferences privadas. Limitaciones: el control es local, usa el reloj del dispositivo y no sustituye límites centralizados en un servidor.

4.5 Backup y componentes

AndroidManifest.xml declara allowBackup=false. backup_rules.xml y data_extraction_rules.xml excluyen base de datos, preferencias y archivos. RegisterActivity y MainActivity están declaradas como no exportadas; LoginActivity es la actividad launcher exportada. Se debe verificar el manifest fusionado del APK nuevo para confirmar también el estado de componentes agregados por bibliotecas.

5. Resumen de mejoras en el código

Control	Archivo(s)	Estado / observación
Consultas SQL parametrizadas	DatabaseHelper.java	Presente en el código revisado.
PBKDF2 + salt	DatabaseHelper.java	100.000 iteraciones; salt aleatoria de 16 bytes; 256 bits.
Bloqueo progresivo	LoginAttemptGuard.java, LoginService.java, PrefsAttemptStore.java	Presente; límite local y dependiente del reloj.
Sesión mínima y privada	SessionManager.java	SharedPreferences MODE_PRIVATE; 7 días; no cifrada.
Backup desactivado	AndroidManifest.xml y res/xml/*backup*.xml	Configurado en código; verificar APK final.
HTTP en claro deshabilitado	AndroidManifest.xml, res/xml/network_security_config.xml	Agregado en esta entrega; requiere recompilar y verificar.
Clave Maps fuera de Git	app/build.gradle.kts, .gitignore, local.properties.example	Implementado; clave histórica aún requiere revocación manual.
Release optimizado	app/build.gradle.kts	R8 optimization activado; no se ha aportado APK release firmado.

6. Plan de pruebas y evidencias

ID	Prueba	Resultado que debe registrarse
P-01	Pruebas de inyección SQL sobre login SQLite	Payload, entrada usada, resultado real y evidencia.
P-02	Verificar política de red / HTTPS	Manifest fusionado y prueba TLS/MobSF sobre APK actualizado.
P-03	Revisar almacenamiento y backup	Verificar BD, preferencias, fotos y comportamiento de backup.
P-04	Validar entradas de registro/login	Casos válidos, inválidos y mensajes observados.
P-05	Ejecutar funciones principales	Login, registro, mapa, ubicación, marcadores, cámara y logout.
P-06	Pruebas JVM	Salida completa de ./gradlew testDebugUnitTest.
P-07	Pruebas instrumentadas	Salida completa de ./gradlew connectedDebugAndroidTest.
P-08	Nuevo análisis MobSF	Reporte asociado al hash del APK actualizado.

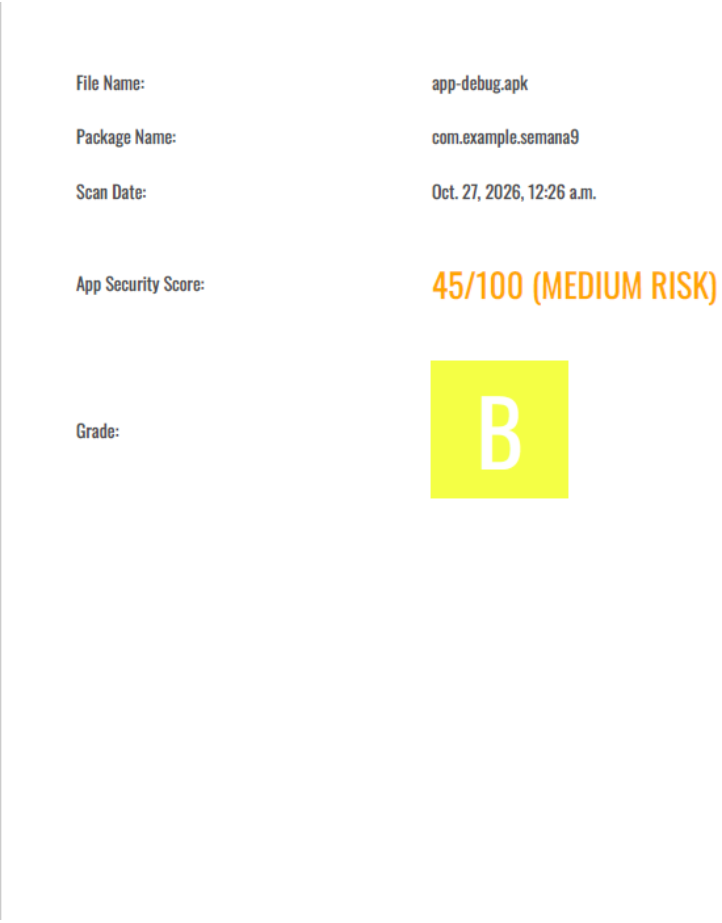
Estado de ejecución en esta revisión: no se ejecutaron Gradle, emulador ni MobSF. Las pruebas existentes en el repositorio son código de prueba, no evidencia de ejecución reciente. Completar esta sección con fecha, versión de Android Studio, dispositivo/emulador y resultados reales.

7. Resultados y limitaciones

La revisión estática del código fuente confirma varios controles de seguridad implementados. Se agregó una política de red para impedir tráfico HTTP en claro. No se puede concluir que el APK final compile, que la configuración nueva quede empaquetada o que todas las pruebas pasen sin ejecutar el proyecto en Android Studio/Gradle y un dispositivo.

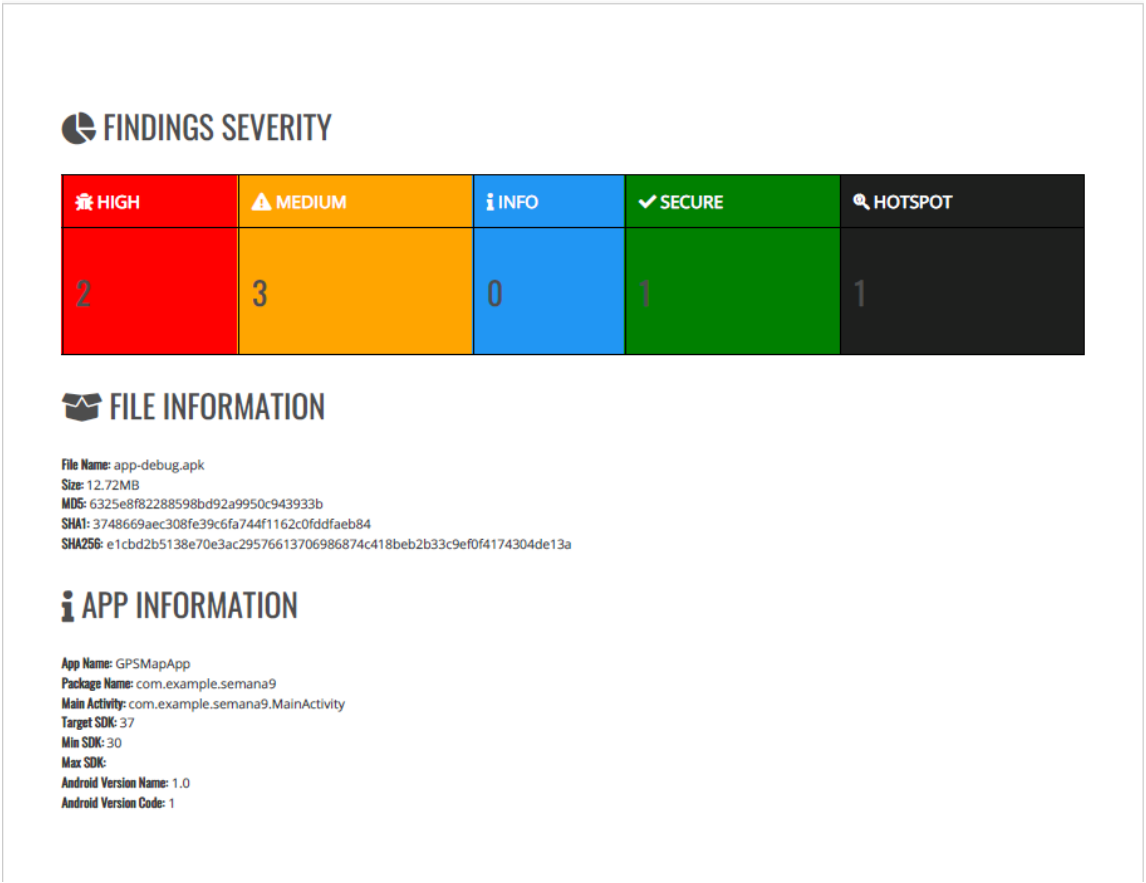
El análisis MobSF histórico (APK debug escaneado el 27-10-2026) informó Security Score 45/100 y hallazgos relacionados con certificado de depuración, debuggable, backup, receiver AndroidX y clave Maps. Es un análisis de un APK anterior y no debe presentarse como resultado del código actualizado.

Figura 6. Resumen del análisis estático de MobSF.



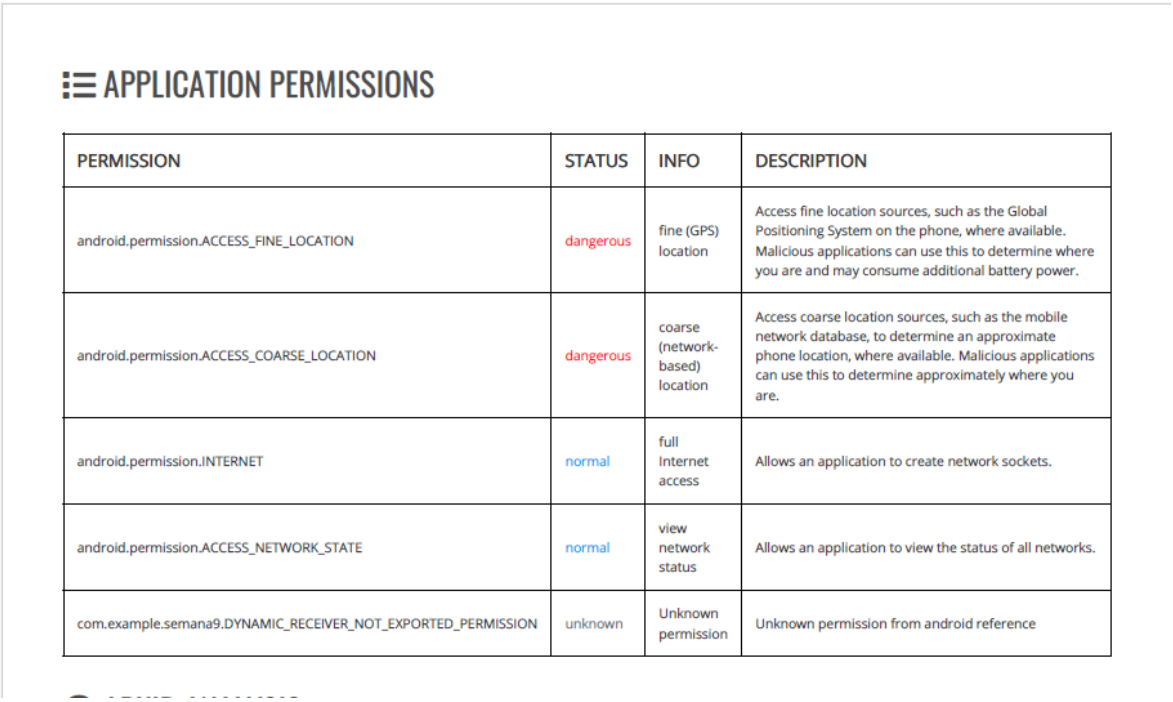
La captura corresponde al resumen del análisis estático realizado por MobSF sobre el archivo app-debug.apk del paquete com.example.semana9. El resultado muestra una puntuación de seguridad de 45/100, clasificada por la herramienta como riesgo medio (Medium Risk), y una calificación B. Esto indica que el APK analizado presenta aspectos de seguridad que requieren revisión y mejoras; la puntuación no significa que la aplicación esté completamente protegida ni que todos sus componentes sean vulnerables. Este resultado corresponde al APK escaneado el 27 de octubre de 2026 y no debe confundirse con una evaluación del APK actualizado después de los cambios. Por eso, se recomienda generar un nuevo APK y repetir el análisis para comprobar el efecto de las mejoras.

Figura 7. Resumen de hallazgos y datos generales de GPSMapApp en MobSF.



Esta captura muestra el resumen de los hallazgos que MobSF detectó en el APK analizado. Se observan 2 hallazgos de severidad alta (HIGH), 3 de severidad media (MEDIUM), 0 informativos (INFO), 1 elemento marcado como seguro (SECURE) y 1 hotspot. Los hallazgos HIGH y MEDIUM requieren revisión porque pueden representar riesgos para la aplicación, pero la captura no indica por sí sola cuáles son esos problemas concretos; para conocerlos es necesario revisar el detalle de cada hallazgo en el informe completo. La sección File Information identifica el archivo app-debug.apk y muestra sus hashes, que sirven para reconocer exactamente el archivo analizado. App Information confirma el nombre GPSMapApp, el paquete com.example.semana9, la actividad principal y los niveles de SDK informados por MobSF.

Figura 8. Permisos solicitados por GPSMapApp según el análisis de MobSF.



APPLICATION PERMISSIONS

PERMISSION	STATUS	INFO	DESCRIPTION
android.permission.ACCESS_FINE_LOCATION	dangerous	fine (GPS) location	Access fine location sources, such as the Global Positioning System on the phone, where available. Malicious applications can use this to determine where you are and may consume additional battery power.
android.permission.ACCESS_COARSE_LOCATION	dangerous	coarse (network-based) location	Access coarse location sources, such as the mobile network database, to determine an approximate phone location, where available. Malicious applications can use this to determine approximately where you are.
android.permission.INTERNET	normal	full Internet access	Allows an application to create network sockets.
android.permission.ACCESS_NETWORK_STATE	normal	view network status	Allows an application to view the status of all networks.
com.example.semana9.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION	unknown	Unknown permission	Unknown permission from android reference

Esta tabla presenta los permisos que MobSF encontró en el APK. Los permisos ACCESS_FINE_LOCATION y ACCESS_COARSE_LOCATION aparecen como dangerous porque permiten acceder a la ubicación precisa y aproximada del dispositivo. En GPSMapApp estos permisos se relacionan con la función de mostrar la ubicación del usuario en Google Maps, por lo que deben solicitarse solo cuando sean necesarios y explicando al usuario para qué se utilizan. Los permisos INTERNET y ACCESS_NETWORK_STATE aparecen como normal: el primero permite realizar conexiones de red y el segundo consultar el estado de la conexión.

8. Conclusiones

GPSMapApp incorpora controles útiles para proteger la autenticación y los datos locales: consultas parametrizadas, contraseñas derivadas con PBKDF2 y salt, control de intentos, sesión mínima, almacenamiento privado y backups desactivados. La política de red agregada impide tráfico HTTP en claro, pero debe comprobarse en un APK recompilado. La clave Maps visible en el artefacto histórico debe revocarse y reemplazarse. Antes de entregar o distribuir, es necesario ejecutar las pruebas JVM e instrumentadas, generar un APK release firmado y repetir el análisis MobSF.

9. Plan de mejora priorizado

Prioridad	Acción	Criterio de cierre
Crítica	Revocar la clave Maps expuesta y crear una nueva restringida.	Clave antigua revocada; nueva restringida por paquete, SHA-1 y API.
Alta	Ejecutar pruebas JVM e instrumentadas.	Salidas completas de Gradle sin fallos.
Alta	Compilar APK nuevo y repetir MobSF.	Reporte nuevo sin la clave antigua y con configuración actual revisada.
Alta	Generar release firmado con keystore propio.	APK/AAB release firmado y analizado.
Media	Verificar manifest fusionado y componentes de bibliotecas.	Componentes exportados justificados y documentados.
Baja	Evaluar cifrado de sesión y límites anti-fuerza-bruta del lado servidor.	Decisión técnica y pruebas documentadas.

10. Referencias

- Código fuente del proyecto GPSMapApp incluido en este repositorio.

- Reporte MobSF histórico de app-debug.apk, escaneado el 27-10-2026 (se conserva solo resumen redactado).
- Android Developers — Security: https://developer.android.com/privacy-and-security
- OWASP Mobile Application Security: https://mas.owasp.org/

9. Evidencias visuales de funcionamiento y pruebas

Las siguientes capturas fueron proporcionadas como evidencia de las pruebas manuales realizadas en el emulador. Muestran la visualización del mapa, las pantallas de autenticación y respuestas de la aplicación ante credenciales incorrectas o campos incompletos. Las imágenes documentan el comportamiento visible; no sustituyen los resultados de pruebas automatizadas ni el análisis TLS/SSL específico de MobSF.

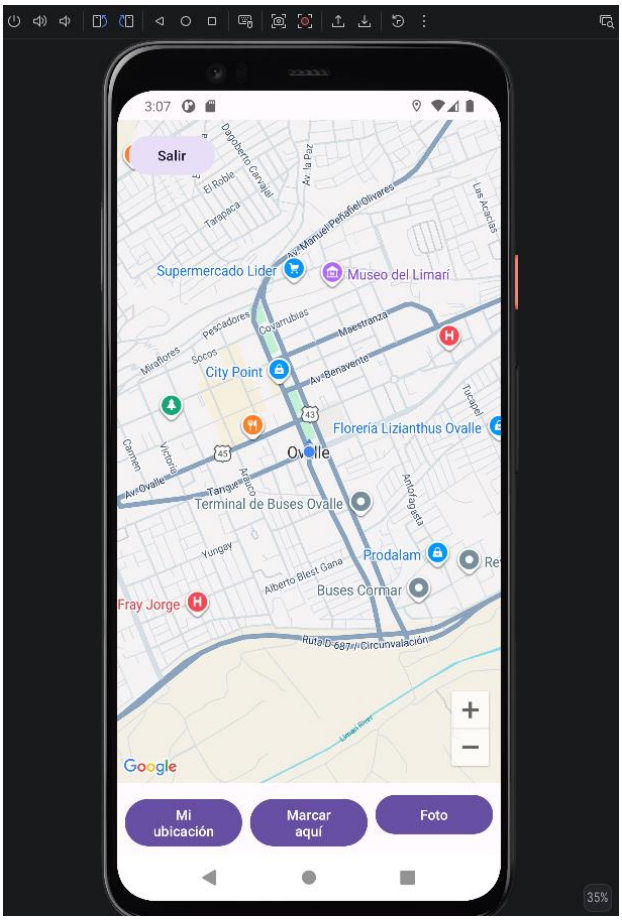


Figura 1. Pantalla principal con Google Maps y controles de ubicación, marcador y fotografía.



Figura 2. Pantalla de inicio de sesión de GPSMapApp.



Figura 3. Formulario de creación de cuenta con usuario, contraseña y confirmación.



Figura 4. Intento de inicio de sesión con credenciales incorrectas; la aplicación muestra un mensaje de rechazo.

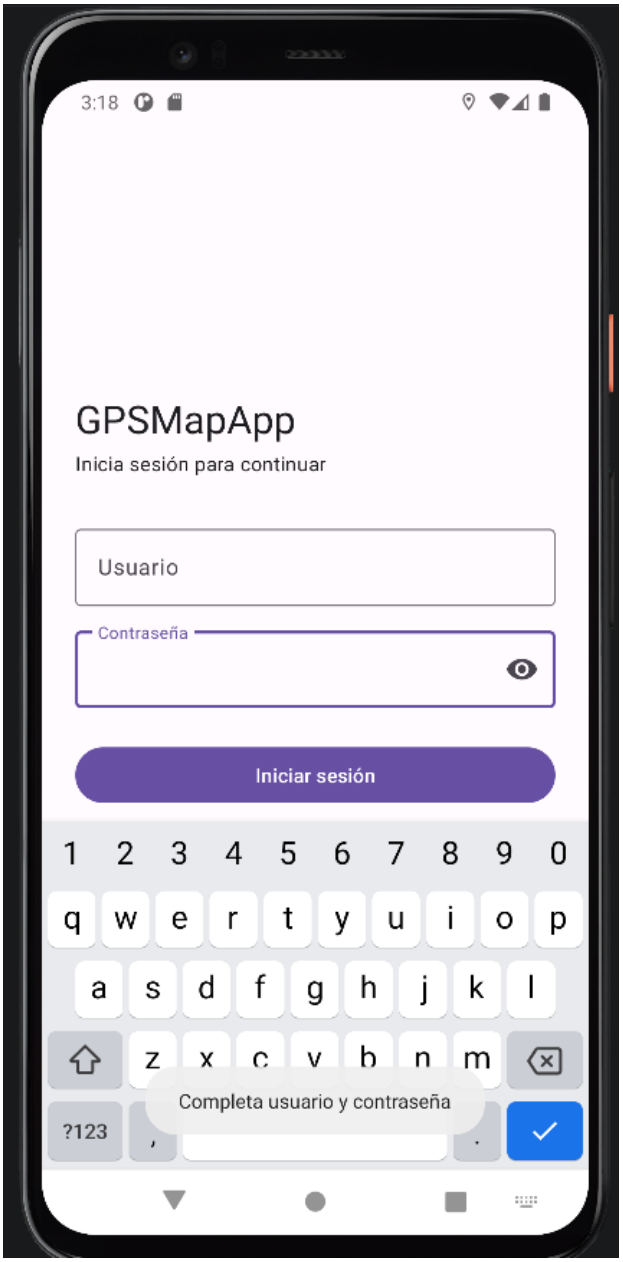


Figura 5. Validación de campos obligatorios al intentar iniciar sesión sin completar usuario y contraseña.

10. Distribución de roles y responsabilidades

Para el desarrollo de la actividad, las responsabilidades se distribuyeron entre los integrantes del equipo de acuerdo con los documentos de seguridad elaborados.

Sebastián Pereira – Best Practices (best_practices.md)

- Identificación y documentación de buenas prácticas de seguridad aplicables a GPSMapApp.
- Descripción de medidas de protección, como el resguardo de datos, el uso de conexiones seguras y la validación de entradas.
- Explicación del aporte de estas prácticas a la seguridad de la aplicación.

Cristian Pereira – Security Tips (security_tips.md)

- Investigación y documentación de recomendaciones para prevenir amenazas de seguridad.
- Análisis de riesgos como SQL Injection y ataques Man-in-the-Middle (MITM).
- Registro de recomendaciones relacionadas con autenticación y autorización.

Matías Mundaca – Security Improvement Program (security_improvement_program.md)

- Elaboración del programa de mejora continua de seguridad.
- Definición del ciclo de revisión, métricas de evaluación y acciones futuras.

Matías Mundaca – Vulnerabilities (vulnerabilities.md)

- Identificación y documentación de vulnerabilidades detectadas durante los análisis de seguridad.
- Registro de evidencias, descripción de riesgos e impacto potencial.
- Documentación de recomendaciones o medidas de mitigación para los hallazgos.

11. Prompts utilizados por cada integrante

A continuación, se muestran los prompts sencillos utilizados como guía para elaborar los archivos asignados a cada integrante.

Sebastián Pereira – best_practices.md

> Ayúdame a hacer el archivo best_practices.md con buenas prácticas para proteger mi aplicación GPSMapApp. Incluye contraseñas, datos de usuarios y seguridad de conexión. Explícalo fácil.

Cristian Pereira – security_tips.md

> Realiza el archivo security_tips.md con consejos para proteger mi aplicación de ataques como SQL Injection y MITM. Explícalo de forma sencilla.

Matías Mundaca – security_improvement_program.md

> Crea un plan para mejorar la seguridad de mi aplicación GPSMapApp. Incluye qué cosas revisar y qué mejoras hacer en el futuro. Hazlo sencillo y ordenado.

Matías Mundaca – vulnerabilities.md

> Desarrolla el archivo vulnerabilities.md con los problemas de seguridad encontrados en mi aplicación usando MobSF. Explica cuáles son, qué riesgos tienen y cómo solucionarlos.